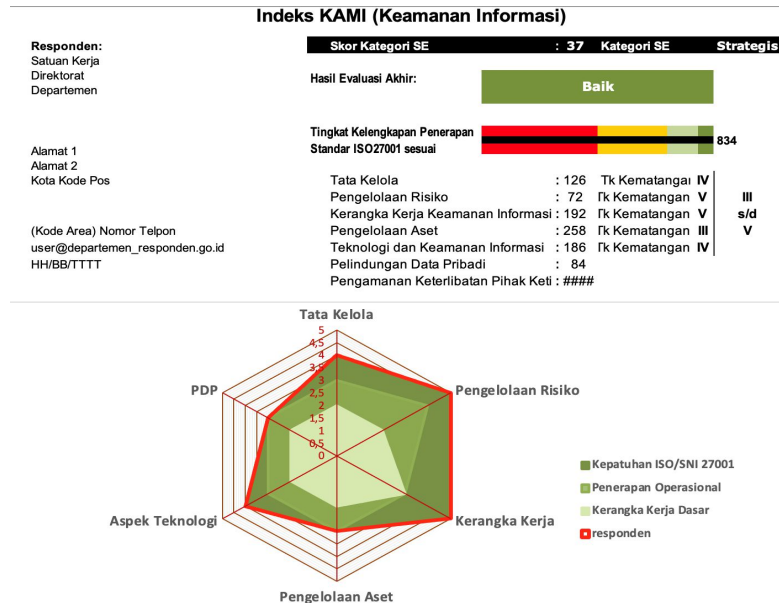


Indeks Keamanan Informasi (Indeks KAMI)

Versi 5.0, Maret 2023



Mengenai Indeks KAMI



Indeks KAMI adalah alat evaluasi untuk menganalisa tingkat kesiapan pengamanan informasi di suatu organisasi. Alat evaluasi ini tidak ditujukan untuk menganalisa kelayakan atau efektifitas bentuk pengamanan yang ada, melainkan sebagai perangkat untuk memberikan gambaran kondisi kesiapan (kelengkapan dan kematangan) kerangka kerja keamanan informasi kepada pimpinan Instansi/Perusahaan. Evaluasi dilakukan terhadap berbagai area yang menjadi target penerapan keamanan informasi dengan ruang lingkup pembahasan yang juga memenuhi semua aspek keamanan yang didefinisikan oleh standar ISO/IEC 27001:2022.

Bentuk evaluasi yang diterapkan dalam indeks KAMI dirancang untuk dapat digunakan oleh suatu organisasi dari berbagai tingkatan, ukuran, maupun tingkat kepentingan penggunaan TIK dalam mendukung terlaksananya proses yang ada. Data yang digunakan dalam evaluasi ini nantinya akan memberikan *snapshot* indeks kesiapan - dari aspek kelengkapan maupun kematangan - kerangka kerja keamanan informasi yang diterapkan dan dapat digunakan sebagai pembandingan dalam rangka menyusun langkah perbaikan dan penetapan prioritasnya.

Alat evaluasi ini kemudian bisa digunakan secara berkala untuk mendapatkan gambaran perubahan kondisi keamanan informasi sebagai hasil dari program kerja yang dijalankan, sekaligus sebagai sarana untuk menyampaikan peningkatan kesiapan kepada pihak yang terkait (*stakeholders*).

Khusus untuk Instansi Pemerintah, penggunaan dan publikasi hasil evaluasi Indeks KAMI merupakan bentuk tanggungjawab penggunaan dana publik sekaligus menjadi sarana untuk meningkatkan kesadaran mengenai kebutuhan keamanan informasi. Pertukaran informasi dan diskusi dengan Instansi pemerintah lainnya sebagai bagian dari penggunaan alat evaluasi Indeks KAMI ini juga menciptakan alur komunikasi antar pengelola keamanan informasi di sektor pemerintah sehingga semua pihak dapat mengambil manfaat dari *lesson learned* yang sudah dilalui.

Petunjuk Penggunaan Alat Evaluasi Indeks Keamanan Informasi (Indeks KAMI)

Alat evaluasi Indeks KAMI ini dapat digunakan oleh organisasi dengan skala nasional, maupun yang berukuran kecil. Penggunaan di Instansi pemerintah dapat dilakukan di tingkat pusat maupun satuan kerja yang ada di tingkatan Direktorat Jenderal, Badan, Pusat atau Direktorat untuk mendapatkan gambaran mengenai kematangan program kerja keamanan informasi yang dijalkannya. Evaluasi ini dianjurkan untuk dilakukan oleh pejabat yang secara langsung bertanggungjawab dan berwenang untuk mengelola keamanan informasi di seluruh cakupan instansinya.

Proses evaluasi dilakukan melalui sejumlah pertanyaan di masing-masing area di bawah ini:

- Kategori Sistem Elektronik yang digunakan Instansi
- Tata Kelola Keamanan Informasi
- Pengelolaan Risiko Keamanan Informasi
- Kerangka Kerja Keamanan Informasi
- Pengelolaan Aset Informasi, dan
- Teknologi dan Keamanan Informasi
- Pelindungan Data Pribadi
- Suplemen: Area evaluasi untuk aspek Pengamanan Keterlibatan Pihak Ketiga Penyedia Layanan.

Pertanyaan yang ada belum tentu dapat dijawab semuanya, akan tetapi yang harus diperhatikan adalah jawaban yang diberikan harus merefleksikan kondisi penerapan keamanan informasi SESUNGGUHNYA. Alat evaluasi ini hanya akan memberikan nilai tambah bagi semua pihak apabila pengisiannya menggunakan azas keterbukaan dan kejujuran.

Sebelum mulai menjawab pertanyaan terkait kesiapan pengamanan informasi, responden diminta untuk mendefinisikan Kategori Sistem Elektronik di Instansinya. Definisi ini bisa dijabarkan untuk tingkat Satuan Kerja baik di tingkat Kementerian/Lembaga, ataupun untuk satuan kerja yang lebih kecil, sampai ke Unit Eselon III. Responden juga diminta untuk mendeskripsikan infrastruktur TIK yang ada dalam satuan kerjanya secara singkat. Tujuan dari proses ini adalah untuk mengelompokkan Sistem Elektronik yang digunakan instansi ke "tingkat" tertentu: Rendah, Tinggi dan Strategis. Dengan pengelompokan ini nantinya bisa dilakukan pemetaan terhadap instansi yang mempunyai karakteristik Sistem Elektronik yang sama.

Pertanyaan dikelompokkan untuk 2 keperluan. Pertama, pertanyaan dikategorikan berdasarkan tingkat kesiapan penerapan pengamanan sesuai dengan **kelengkapan** kontrol yang diminta oleh standar ISO/IEC 27001:2022. Dalam pengelompokan ini responden diminta untuk memberi tanggapan mulai dari area yang terkait dengan bentuk kerangka kerja dasar keamanan informasi (pertanyaan diberi label "1"), efektifitas dan konsistensi penerapannya (label "2"), sampai dengan kemampuan untuk selalu meningkatkan kinerja keamanan informasi (label "3"). Tingkat terakhir ini sesuai dengan kesiapan minimum yang diprasyarkan oleh proses sertifikasi standar ISO/IEC 27001:2022.

Setiap jawaban diberikan skor yang nantinya dikonsolidasi untuk menghasilkan angka indeks sekaligus digunakan untuk menampilkan hasil evaluasi dalam *dashboard* di akhir proses ini. Skor yang diberikan untuk jawaban pertanyaan sesuai tingkat kematangannya

Status Pengamanan	Kategori Pengamanan		
	1	2	3
Tidak Dilakukan	0	0	0
Dalam Perencanaan	1	2	3
Dalam Penerapan atau Diterapkan Sebagian	2	4	6
Diterapkan secara Menyeluruh	3	6	9

(Catatan: untuk keseluruhan area pengamanan, pengisian pertanyaan dengan label "3" hanya dapat memberikan hasil/nilai apabila semua pertanyaan dengan label "1" sudah diisi dengan status "Diterapkan Menyeluruh" dan/atau paling rendah hanya terdapat status "Diterapkan Sebagian" maksimal sebanyak dua).

Hasil dari penjumlahan skor untuk masing-masing area ditampilkan dalam diagram radar dengan latar belakang area untuk tingkat maksimal kematangan 1 s/d 3. Dalam diagram ini bisa dilihat perbandingan antara kondisi kesiapan sebagai hasil dari proses evaluasi dengan acuan tingkat kematangan yang ada.

Dengan membaca diagram ini, pimpinan instansi dapat melihat kebutuhan pembenahan yang diperlukan dan korelasi antara berbagai area penerapan keamanan informasi. Adapun korelasi antara Kategori Sistem Elektronik dengan Status Kesiapan didefinisikan melalui tabel berikut:

KATEGORI SISTEM ELEKTRONIK				
Rendah		Skor Akhir		Status Kesiapan
10	15	0	247	Tidak Layak
		248	443	Pemenuhan Kerangka Kerja Dasar
		444	760	Cukup Baik
		761	916	Baik
Tinggi		Skor Akhir		Status Kesiapan
16	34	0	387	Tidak Layak
		388	646	Pemenuhan Kerangka Kerja Dasar
		647	828	Cukup Baik
		829	916	Baik
Strategis		Skor Akhir		Status Kesiapan
35	50	0	472	Tidak Layak
		473	760	Pemenuhan Kerangka Kerja Dasar
		761	864	Cukup Baik
		865	916	Baik

Pengelompokan kedua dilakukan berdasarkan tingkat **kematangan** penerapan pengamanan dengan kategorisasi yang mengacu kepada tingkatan kematangan yang digunakan oleh keangka kerja COBIT atau CMMI. Tingkat kematangan ini nantinya akan digunakan sebagai alat untuk melaporkan pemetaan dan pemeringkatan kesiapan keamanan informasi di Kementerian/Lembaga.

Untuk keperluan Indeks KAMI, tingkat kematangan tersebut didefinisikan sebagai:

- Tingkat I - Kondisi Awal
- Tingkat II - Penerapan Kerangka Kerja Dasar
- Tingkat III - Terdefinisi dan Konsisten
- Tingkat IV - Terkelola dan Terukur
- Tingkat V - Optimal

Untuk membantu memberikan uraian yang lebih detil, tingkatan ini ditambah dengan tingkatan antara - I+, II+, III+, dan IV+, sehingga total terdapat 9 tingkatan kematangan. Sebagai awal, semua responden akan diberikan kategori kematangan Tingkat I. Sebagai padanan terhadap standar ISO/IEC 2700:2013, tingkat kematangan yang diharapkan untuk ambang batas minimum kesiapan sertifikasi adalah Tingkat III+.

Ilustrasi di bawah menunjukkan label pengelompokan kematangan (kolom di sebelah kanan nomor urut) dan kelengkapan (kolom di sebelah kiri pertanyaan).

Bagian II: Tata Kelola Keamanan Informasi			
Bagian ini mengevaluasi kesiapan bentuk tata kelola keamanan informasi beserta Instansi/fungsi, tugas dan tanggung jawab pengelola keamanan informasi.			
[Penilaian] Tidak Dilakukan; Dalam Perencanaan; Dalam Penerapan atau Diterapkan Sebagian; Diterapkan Secara Menyeluruh			Status
#	Fungsi/Instansi Keamanan Informasi		
2.1	II	1	Apakah pimpinan Instansi anda secara prinsip dan resmi bertanggungjawab terhadap pelaksanaan program keamanan informasi (misal yang tercantum dalam ITSP), termasuk penetapan kebijakan terkait?
2.2	II	1	Apakah Instansi anda memiliki fungsi atau bagian yang secara spesifik mempunyai tugas dan tanggungjawab mengelola keamanan informasi dan menjaga kepatuhannya?
2.3	II	1	Apakah pejabat/petugas pelaksana pengamanan informasi mempunyai wewenang yang sesuai untuk menerapkan dan menjamin kepatuhan program keamanan informasi?
2.4	II	1	Apakah penanggungjawab pelaksanaan pengamanan informasi diberikan alokasi sumber daya yang sesuai untuk mengelola dan menjamin kepatuhan program keamanan informasi?
2.5	II	1	Apakah peran pelaksana pengamanan informasi yang mencakup semua keperluan dipetakan dengan lengkap, termasuk kebutuhan audit internal dan persyaratan segregasi kewenangan?
2.6	II	1	Apakah Instansi anda sudah mendefinisikan persyaratan/standar kompetensi dan keahlian pelaksana pengelolaan keamanan informasi?
2.7	II	1	Apakah semua pelaksana pengamanan informasi di Instansi anda memiliki kompetensi dan keahlian yang memadai sesuai persyaratan/standar yang berlaku?
2.8	II	1	Apakah instansi anda sudah menerapkan program sosialisasi dan peningkatan pemahaman untuk keamanan informasi, termasuk kepentingan kepatuhannya bagi semua pihak yang terkait?
2.9	II	2	Apakah Instansi anda menerapkan program peningkatan kompetensi dan keahlian untuk pejabat dan petugas pelaksana pengelolaan keamanan informasi?
2.10	II	2	Apakah instansi anda sudah mengintegrasikan keperluan/persyaratan keamanan informasi dalam proses kerja yang ada?

Kedua pengelompokan ini dapat dipetakan (lihat gambar di bawah) untuk memberikan dua sudut pandang yang berbeda: tingkat kelengkapan pengamanan dan tingkat kematangan pengamanan. Instansi responden dapat menggunakan metrik ini sebagai target program keamanan informasi.



Indeks KAMI sebaiknya digunakan 2X dalam setahun sebagai alat untuk melakukan tinjauan ulang kesiapan keamanan informasi sekaligus untuk mengukur keberhasilan inisiatif perbaikan yang diterapkan, dengan pencapaian tingkat kelengkapan atau kematangan tertentu.

Suplemen

Perkembangan teknologi yang pesat dan pola bisnis yang dinamis menyebabkan munculnya risiko keamanan informasi baru. Keterlibatan pihak ketiga dalam rantai pasok (supply chain) layanan suatu instansi/perusahaan menimbulkan risiko terkait keberadaan/keterlibatan pihak eksternal tersebut.

Untuk menilai kesiapan instansi/perusahaan dalam mengelola risiko di area baru ini, pada revisi 5.0 disediakan modul suplemen yang membahas aspek kesiapan pengamanan untuk ketiga aspek tersebut.

Penggunaan modul suplemen untuk evaluasi kesiapan Pengamanan Keterlibatan Pihak Ketiga digunakan sesuai konteks atau cakupan yang ada. Responden hanya perlu menjawab area evaluasi yang berlaku.

Butir-butir evaluasi kesiapan pengamanan yang disusun untuk setiap area merupakan persyaratan dasar yang bagi instansi/perusahaan yang terpapar risiko terkait area tersebut.

Hasil penilaian evaluasi kesiapan Pengamanan Keterlibatan Pihak Ketiga disampaikan dalam bentuk persentase (%) dengan obyektif/sasaran pencapaian maksimal.

Indeks Keamanan Informasi (Indeks KAMI)

Identitas Instansi atau Perusahaan	<i>Pemerintah Aceh Pemerintah Kabupaten Aceh Tengah Dinas Komunikasi dan Informatika Kabupaten Aceh Tengah</i>
Alamat	<i>Komplek Setdakab Aceh Tengah Alamat 2 Kota Kode Pos</i>
Nomor Telpon	<i>(Kode Area) Nomor Telpon</i>
Email	diskominfo@acehtengahkab.go.id
Pengisi Lembar Evaluasi Jabatan	<i>Mansyur Ramadhan Arita, A.Md Pengelola Layanan Operasional</i>
Tanggal Pengisian	<i>13 April 2026</i>
Deskripsi Ruang Lingkup	<i>Dinas Komunikasi dan Informatika Kabupaten Aceh Tengah</i>

Bagian I: Kategori Sistem Elektronik		
Bagian ini mengevaluasi tingkat atau kategori sistem elektronik yang digunakan		
[Kategori Sistem Elektronik] Rendah; Tinggi; Strategis		Status
#	Karakteristik Instansi/Perusahaan	
1.1	Nilai investasi sistem elektronik yang terpasang [A] Lebih dari Rp.30 Miliar [B] Lebih dari Rp.3 Miliar s/d Rp.30 Miliar [C] Kurang dari Rp.3 Miliar	C
1.2	Total anggaran operasional tahunan yang dialokasikan untuk pengelolaan Sistem Elektronik [A] Lebih dari Rp.10 Miliar [B] Lebih dari Rp.1 Miliar s/d Rp.10 Miliar [C] Kurang dari Rp.1 Miliar	C
1.3	Memiliki kewajiban kepatuhan terhadap Peraturan atau Standar tertentu [A] Peraturan atau Standar nasional dan internasional [B] Peraturan atau Standar nasional [C] Tidak ada Peraturan khusus	B
1.4	Menggunakan teknik kriptografi khusus untuk keamanan informasi dalam Sistem Elektronik [A] Teknik kriptografi khusus yang disertifikasi oleh Negara [B] Teknik kriptografi sesuai standar industri, tersedia secara publik atau dikembangkan sendiri [C] Tidak ada penggunaan teknik kriptografi	C
1.5	Jumlah pengguna Sistem Elektronik [A] Lebih dari 5.000 pengguna [B] 1.000 sampai dengan 5.000 pengguna [C] Kurang dari 1.000 pengguna	C
1.6	Data pribadi yang dikelola Sistem Elektronik [A] Data pribadi yang memiliki hubungan dengan Data Pribadi lainnya [B] Data pribadi yang bersifat individu dan/atau data pribadi yang terkait dengan kepemilikan badan usaha [C] Tidak ada data pribadi	C
1.7	Tingkat klasifikasi/kekritisitas Data yang ada dalam Sistem Elektronik, relatif terhadap ancaman upaya penyerangan atau penerobosan keamanan informasi [A] Sangat Rahasia [B] Rahasia dan/ atau Terbatas [C] Biasa	C
1.8	Tingkat kekritisitas proses yang ada dalam Sistem Elektronik, relatif terhadap ancaman upaya penyerangan atau penerobosan keamanan informasi [A] Proses yang berisiko mengganggu hajat hidup orang banyak dan memberi dampak langsung pada layanan publik [B] Proses yang berisiko mengganggu hajat hidup orang banyak dan memberi dampak tidak langsung [C] Proses yang hanya berdampak pada bisnis perusahaan	B
1.9	Dampak dari kegagalan Sistem Elektronik [A] Membahayakan pertahanan keamanan negara [B] Tidak tersedianya layanan publik berskala nasional atau berdampak pada layanan di sektor lain [C] Tidak tersedianya layanan publik dalam 1 propinsi atau internal 1 instansi/perusahaan	C
1.10	Potensi kerugian atau dampak negatif dari insiden ditembusnya keamanan informasi Sistem Elektronik (sabotase, terorisme) [A] Menimbulkan korban jiwa [B] Terbatas pada kerugian finansial [C] Mengakibatkan gangguan operasional sementara (tidak membahayakan dan mengakibatkan kerugian finansial)	C
Skor penetapan Kategori Sistem Elektronik		12

Bagian II: Tata Kelola Keamanan Informasi

Bagian ini mengevaluasi kesiapan bentuk tata kelola keamanan informasi instansi/perusahaan beserta fungsi, tugas dan tanggung jawab pengelola keamanan informasi.

[Penilaian] Tidak Dilakukan; Dalam Perencanaan; Dalam Penerapan atau Diterapkan Sebagian; Diterapkan Secara Menyeluruh			Status
#	Fungsi/Organisasi Keamanan Informasi		
2.1	II	1 Apakah pimpinan instansi/perusahaan anda secara prinsip dan resmi bertanggungjawab terhadap pelaksanaan program keamanan informasi (misal yang tercantum dalam ITSP), termasuk penetapan kebijakan terkait?	Dalam Penerapan / Diterapkan Sebagian
2.2	II	1 Apakah instansi/perusahaan anda memiliki fungsi atau bagian yang secara spesifik mempunyai tugas dan tanggungjawab mengelola keamanan informasi dan menjaga kepatuhannya?	Diterapkan Secara Menyeluruh
2.3	II	1 Apakah pejabat/petugas pelaksana pengamanan informasi mempunyai wewenang yang sesuai untuk menerapkan dan menjamin kepatuhan program keamanan informasi?	Dalam Penerapan / Diterapkan Sebagian
2.4	II	1 Apakah penanggungjawab pelaksanaan pengamanan informasi diberikan alokasi sumber daya yang sesuai untuk mengelola dan menjamin kepatuhan program keamanan informasi?	Dalam Perencanaan
2.5	II	1 Apakah peran pelaksana pengamanan informasi yang mencakup semua keperluan dipetakan dengan lengkap, termasuk kebutuhan audit internal dan persyaratan segregasi kewenangan?	Dalam Penerapan / Diterapkan Sebagian
2.6	II	1 Apakah instansi/perusahaan anda sudah mendefinisikan persyaratan/standar kompetensi dan keahlian pelaksana pengelolaan keamanan informasi?	Dalam Penerapan / Diterapkan Sebagian
2.7	II	1 Apakah semua pelaksana pengamanan informasi di instansi/perusahaan anda memiliki kompetensi dan keahlian yang memadai sesuai persyaratan/standar yang berlaku?	Dalam Penerapan / Diterapkan Sebagian
2.8	II	1 Apakah instansi/perusahaan anda sudah menerapkan program sosialisasi dan peningkatan pemahaman untuk keamanan informasi, termasuk kepentingan kepatuhannya bagi semua pihak yang terkait?	Diterapkan Secara Menyeluruh
2.9	II	2 Apakah instansi/perusahaan anda menerapkan program peningkatan kompetensi dan keahlian untuk pejabat dan petugas pelaksana pengelolaan keamanan informasi?	Dalam Perencanaan
2.10	II	2 Apakah instansi/perusahaan anda sudah mengintegrasikan keperluan/persyaratan keamanan informasi dalam proses kerja yang ada?	Dalam Penerapan / Diterapkan Sebagian
2.11	II	2 Apakah instansi/perusahaan anda sudah mengidentifikasi data pribadi yang digunakan dalam proses kerja dan menerapkan pengamanan sesuai dengan peraturan perundangan yang berlaku?	Diterapkan Secara Menyeluruh
2.12	II	2 Apakah tanggungjawab pengelolaan keamanan informasi mencakup koordinasi dengan pihak pengelola/pengguna aset informasi internal dan eksternal maupun pihak lain yang berkepentingan, untuk mengidentifikasi persyaratan/kebutuhan pengamanan (misal: pertukaran informasi atau kerjasama yang melibatkan informasi penting) dan menyelesaikan permasalahan yang ada?	Dalam Penerapan / Diterapkan Sebagian
2.13	II	2 Apakah pengelola keamanan informasi secara proaktif berkoordinasi dengan satker terkait (SDM, Legal/Hukum, Umum, Keuangan dll) dan pihak eksternal yang berkepentingan (misal: regulator, aparat keamanan) untuk menerapkan dan menjamin kepatuhan pengamanan informasi terkait proses kerja yang melibatkan berbagai pihak?	Dalam Penerapan / Diterapkan Sebagian
2.14	III	2 Apakah tanggungjawab untuk memutuskan, merancang, melaksanakan dan mengelola langkah kelangsungan layanan TIK (<i>business continuity</i> dan <i>disaster recovery plans</i>) sudah didefinisikan dan dialokasikan?	Dalam Perencanaan
2.15	III	2 Apakah penanggungjawab pengelolaan keamanan informasi melaporkan kondisi, kinerja/efektifitas dan kepatuhan program keamanan informasi kepada pimpinan instansi/perusahaan secara rutin dan resmi?	Diterapkan Secara Menyeluruh
2.16	III	2 Apakah kondisi dan permasalahan keamanan informasi di instansi/perusahaan anda menjadi konsiderans atau bagian dari proses pengambilan keputusan strategis di instansi/perusahaan anda?	Dalam Penerapan / Diterapkan Sebagian
2.17	IV	3 Apakah pimpinan satuan kerja di instansi/perusahaan anda menerapkan program khusus untuk mematuhi tujuan dan sasaran kepatuhan pengamanan informasi, khususnya yang mencakup aset informasi yang menjadi tanggungjawabnya?	Diterapkan Secara Menyeluruh
2.18	IV	3 Apakah instansi/perusahaan anda sudah mendefinisikan metrik, paramater dan proses pengukuran kinerja pengelolaan keamanan informasi yang mencakup mekanisme, waktu pengukuran, pelaksanaannya, pemantauannya dan eskalasi pelaporannya?	Dalam Perencanaan
2.19	IV	3 Apakah instansi/perusahaan anda sudah menerapkan program penilaian kinerja pengelolaan keamanan informasi bagi individu (pejabat & petugas) pelaksanaannya?	Dalam Penerapan / Diterapkan Sebagian
2.20	IV	3 Apakah instansi/perusahaan anda sudah menerapkan target dan sasaran pengelolaan keamanan informasi untuk berbagai area yang relevan, mengevaluasi pencapaiannya secara rutin, menerapkan langkah perbaikan untuk mencapai sasaran yang ada, termasuk pelaporan statusnya kepada pimpinan instansi/perusahaan?	Dalam Perencanaan
2.21	IV	3 Apakah instansi/perusahaan anda sudah mengidentifikasi legislasi, perangkat hukum dan standar lainnya terkait keamanan informasi yang harus dipatuhi dan menganalisa tingkat kepatuhannya?	Dalam Penerapan / Diterapkan Sebagian

2.22	IV	3	Apakah instansi/perusahaan anda sudah mendefinisikan kebijakan dan langkah penanggulangan insiden keamanan informasi yang menyangkut pelanggaran hukum (pidana dan perdata)?	Dalam Perencanaan
			Total Nilai Evaluasi Tata Kelola	49

Bagian III: Pengelolaan Risiko Keamanan Informasi				
Bagian ini mengevaluasi kesiapan penerapan pengelolaan risiko keamanan informasi sebagai dasar penerapan strategi keamanan informasi.				
[Penilaian] Tidak Dilakukan; Dalam Perencanaan; Dalam Penerapan atau Diterapkan Sebagian; Diterapkan Secara Menyeluruh				Status
#	Kajian Risiko Keamanan Informasi			
3.1	II	1	Apakah instansi/perusahaan anda mempunyai program kerja pengelolaan risiko keamanan informasi yang terdokumentasi dan secara resmi digunakan?	Dalam Perencanaan
3.2	II	1	Apakah instansi/perusahaan anda sudah menetapkan penanggung jawab manajemen risiko dan eskalasi pelaporan status pengelolaan risiko keamanan informasi sampai ke tingkat pimpinan?	Dalam Penerapan / Diterapkan Sebagian
3.3	II	1	Apakah instansi/perusahaan anda mempunyai kerangka kerja pengelolaan risiko keamanan informasi yang terdokumentasi dan secara resmi digunakan?	Dalam Perencanaan
3.4	II	1	Apakah kerangka kerja pengelolaan risiko ini mencakup definisi dan hubungan tingkat klasifikasi aset informasi, tingkat ancaman, kemungkinan terjadinya ancaman tersebut dan dampak kerugian terhadap instansi/perusahaan anda?	Dalam Penerapan / Diterapkan Sebagian
3.5	II	1	Apakah instansi/perusahaan anda sudah menetapkan ambang batas tingkat risiko yang dapat diterima?	Tidak Dilakukan
3.6	II	1	Apakah instansi/perusahaan anda sudah mendefinisikan kepemilikan dan pihak pengelola (<i>custodian</i>) aset informasi yang ada, termasuk aset utama/penting dan proses kerja utama yang menggunakan aset tersebut?	Dalam Perencanaan
3.7	II	1	Apakah ancaman dan kelemahan yang terkait dengan aset informasi, terutama untuk setiap aset utama sudah teridentifikasi?	Dalam Perencanaan
3.8	II	1	Apakah dampak kerugian yang terkait dengan hilangnya/terganggunya fungsi aset utama sudah ditetapkan sesuai dengan definisi yang ada?	Tidak Dilakukan
3.9	II	1	Apakah instansi/perusahaan anda sudah menjalankan inisiatif analisa/kajian risiko keamanan informasi secara terstruktur terhadap aset informasi yang ada (untuk nantinya digunakan dalam mengidentifikasi langkah mitigasi atau penanggulangan yang menjadi bagian dari program pengelolaan keamanan informasi)?	Dalam Perencanaan
3.10	II	1	Apakah instansi/perusahaan anda sudah menyusun langkah mitigasi dan penanggulangan risiko yang ada?	Dalam Penerapan / Diterapkan Sebagian
3.11	III	2	Apakah langkah mitigasi risiko disusun sesuai tingkat prioritas dengan target penyelesaiannya dan penanggungjawabnya, dengan memastikan efektifitas penggunaan sumber daya yang dapat menurunkan tingkat risiko ke ambang batas yang bisa diterima dengan meminimalisir dampak terhadap operasional layanan TIK?	Dalam Penerapan / Diterapkan Sebagian
3.12	III	2	Apakah status penyelesaian langkah mitigasi risiko dipantau secara berkala, untuk memastikan penyelesaian atau kemajuan kerjanya?	Dalam Penerapan / Diterapkan Sebagian
3.13	IV	2	Apakah penyelesaian langkah mitigasi yang sudah diterapkan dievaluasi, melalui proses yang obyektif/terukur untuk memastikan konsistensi dan efektifitasnya?	Dalam Perencanaan
3.14	IV	2	Apakah profil risiko berikut bentuk mitigasinya secara berkala dikaji ulang untuk memastikan akurasi dan validitasnya, termasuk merevisi profil tersebut apabila ada perubahan kondisi yang signifikan atau keperluan penerapan bentuk pengamanan baru?	Dalam Perencanaan
3.15	V	3	Apakah kerangka kerja pengelolaan risiko secara berkala dikaji untuk memastikan/meningkatkan efektifitasnya?	Dalam Perencanaan
3.16	V	3	Apakah pengelolaan risiko menjadi bagian dari kriteria proses penilaian obyektif kinerja efektifitas pengamanan?	Diterapkan Secara Menyeluruh
Total Nilai Evaluasi Pengelolaan Risiko Keamanan Informasi				23

Bagian IV: Kerangka Kerja Pengelolaan Keamanan Informasi			
Bagian ini mengevaluasi kelengkapan dan kesiapan kerangka kerja (kebijakan & prosedur) pengelolaan keamanan informasi dan strategi penerapannya.			
[Penilaian] Tidak Dilakukan; Dalam Perencanaan; Dalam Penerapan atau Diterapkan Sebagian; Diterapkan Secara Menyeluruh			Status
#	Penyusunan dan Pengelolaan Kebijakan & Prosedur Keamanan Informasi		
4.1	II	1	Apakah kebijakan dan prosedur maupun dokumen lainnya yang diperlukan terkait keamanan informasi sudah disusun dan dituliskan dengan jelas, dengan mencantumkan peran dan tanggung jawab pihak-pihak yang diberikan wewenang untuk menerapkannya?
4.2	II	1	Apakah kebijakan keamanan informasi sudah ditetapkan secara formal, dipublikasikan kepada semua staf/karyawan termasuk pihak terkait dan dengan mudah diakses oleh pihak yang membutuhkannya?
4.3	II	1	Apakah tersedia mekanisme untuk mengelola dokumen kebijakan dan prosedur keamanan informasi, termasuk penggunaan daftar induk, distribusi, penarikan dari peredaran dan penyimpanannya?
4.4	II	1	Apakah tersedia proses (mencakup pelaksana, mekanisme, jadwal, materi, dan sasarannya) untuk mengkomunikasikan kebijakan keamanan informasi (dan perubahannya) kepada semua pihak terkait, termasuk pihak ketiga?
4.5	II	1	Apakah keseluruhan kebijakan dan prosedur keamanan informasi yang ada merefleksikan kebutuhan mitigasi dari hasil kajian risiko keamanan informasi, maupun sasaran/obyektif tertentu yang ditetapkan oleh pimpinan instansi/perusahaan?
4.6	II	1	Apakah tersedia proses untuk mengidentifikasi kondisi yang membahayakan keamanan informasi dan menetapkan sebagai insiden keamanan informasi untuk ditindak lanjut sesuai prosedur yang diberlakukan?
4.7	II	1	Apakah aspek keamanan informasi yang mencakup pelaporan insiden, menjaga kerahasiaan, HAKI, data terbit penggunaan dan pengamanan aset maupun layanan TIK tercantum dalam kontrak dengan pihak ketiga?
4.8	II	2	Apakah konsekuensi dari pelanggaran kebijakan keamanan informasi sudah didefinisikan, dikomunikasikan dan ditegakkan?
4.9	II	2	Apakah tersedia prosedur resmi untuk mengelola suatu pengecualian terhadap penerapan keamanan informasi, termasuk proses untuk menindak lanjut konsekuensi dari kondisi ini?
4.10	III	2	Apakah instansi/perusahaan anda sudah menerapkan kebijakan dan prosedur operasional untuk mengelola implementasi <i>security patch</i> , alokasi tanggung jawab untuk memonitor adanya rilis <i>security patch</i> baru, memastikan pemasangannya dan melaporkannya?
4.11	III	2	Apakah instansi/perusahaan anda sudah membahas aspek keamanan informasi dalam manajemen proyek yang terkait dengan ruang lingkup?
4.12	III	2	Apakah instansi/perusahaan anda sudah menerapkan proses untuk mengevaluasi risiko terkait rencana pembelian (atau implementasi) sistem baru dan menanggulangi permasalahan yang muncul?
4.13	III	2	Apakah instansi/perusahaan anda sudah menerapkan proses pengembangan sistem yang aman (<i>Secure SDLC</i>) dengan menggunakan prinsip atau metode sesuai standar platform teknologi yang digunakan?
4.14	III	2	Apabila penerapan suatu sistem mengakibatkan timbulnya risiko baru atau terjadinya ketidakpatuhan terhadap kebijakan yang ada, apakah ada proses untuk menanggulangi hal ini, termasuk penerapan pengamanan baru (<i>compensating control</i>) dan jadwal penyelesaiannya?
4.15	III	2	Apakah instansi/perusahaan anda memiliki fungsi atau bagian yang secara spesifik mempunyai tugas dan tanggungjawab terkait perkembangan ancaman keamanan informasi dan pengelolannya (<i>threat intelligence</i>)?
4.16	III	2	Apakah tersedia kerangka kerja pengelolaan perencanaan kelangsungan layanan TIK (<i>business continuity planning</i>) yang mendefinisikan persyaratan/konsiderans keamanan informasi, termasuk penjadwalan uji cobanya?
4.17	III	3	Apakah kebijakan dan prosedur yang diperlukan terkait perkembangan ancaman keamanan informasi dan pengelolannya (<i>threat intelligence</i>) sudah disusun dan dituliskan dengan jelas (proses pengumpulan data, analisa, dan identifikasi ancaman), dengan mencantumkan peran dan tanggung jawab pihak-pihak yang diberikan wewenang untuk menerapkannya?
4.18	III	3	Apakah hasil analisis perkembangan ancaman keamanan informasi disampaikan kepada pihak yang bertanggung jawab untuk mitigasi risiko, dan memantau perkembangan mitigasi tersebut?
4.19	III	3	Apakah perencanaan pemulihan bencana terhadap layanan TIK (<i>disaster recovery plan</i>) sudah mendefinisikan komposisi, peran, wewenang dan tanggungjawab tim yang ditunjuk?
	III	3	Apakah perencanaan pemulihan bencana terhadap layanan TIK (<i>disaster recovery plan</i>) sudah menentukan Recovery Time Objective (RTO) dan Recovery Point Objective (RPO) ? RTO - Tujuan yang ditetapkan instansi/perusahaan untuk jangka waktu maksimum yang diperlukan untuk memulihkan operasi normal setelah terjadi gangguan yang mengakibatkan berhentinya sistem RPO - Jumlah maksimum data yang dapat ditoleransi oleh instansi/perusahaan jika hilang. Parameter ini diukur dalam waktu: dari saat kegagalan terjadi hingga pencadangan data valid terakhir Anda.
4.20	III	3	Apakah uji coba perencanaan pemulihan bencana terhadap layanan TIK (<i>disaster recovery plan</i>) sudah dilakukan minimal sekali dalam setahun atau apabila ada keperluan yang mendesak (seperti perubahan infrastruktur), dilaksanakan sesuai jadwal penerapan perubahannya?
4.21	IV	3	Apakah hasil dari perencanaan pemulihan bencana terhadap layanan TIK (<i>disaster recovery plan</i>) dievaluasi untuk menerapkan langkah perbaikan atau pembenahan yang diperlukan - misal, apabila hasil uji coba menunjukkan bahwa proses pemulihan tidak bisa (gagal) memenuhi persyaratan yang ada?
4.22	IV	3	Apakah seluruh kebijakan dan prosedur keamanan informasi dievaluasi kelayakannya secara berkala?
#	Pengelolaan Strategi dan Program Keamanan Informasi		
4.23	II	1	Apakah instansi/perusahaan anda mempunyai strategi penerapan keamanan informasi sesuai hasil analisa risiko yang penerapannya dilakukan sebagai bagian dari rencana kerja organisasi?
4.24	II	1	Apakah instansi/perusahaan anda mempunyai strategi penggunaan teknologi keamanan informasi yang penerapan dan pemutakhirannya disesuaikan dengan kebutuhan dan perubahan profil risiko?
4.25	III	1	Apakah strategi penerapan keamanan informasi direalisasikan sebagai bagian dari pelaksanaan program kerja organisasi anda?
4.26	III	1	Apakah instansi/perusahaan anda memiliki dan melaksanakan program audit internal yang dilakukan oleh pihak independen dengan cakupan keseluruhan aset informasi, kebijakan dan prosedur keamanan yang ada (atau sesuai dengan standar yang berlaku)?
4.27	III	1	Apakah audit internal tersebut mengevaluasi tingkat kepatuhan, konsistensi dan efektivitas penerapan keamanan informasi?
4.28	III	2	Apakah hasil audit internal tersebut dikaji/dievaluasi untuk mengidentifikasi langkah pembenahan dan pencegahan, ataupun inisiatif peningkatan kinerja keamanan informasi?
4.29	III	2	Apakah hasil audit internal dilaporkan kepada pimpinan organisasi untuk menetapkan langkah perbaikan atau program peningkatan kinerja keamanan informasi?
4.30	IV	3	Apabila ada keperluan untuk merevisi kebijakan dan prosedur yang berlaku, apakah ada analisa untuk menilai aspek finansial (dampak biaya dan keperluan anggaran) ataupun perubahan terhadap infrastruktur dan pengelolaan perubahannya, sebagai prasyarat untuk menerapkannya?
4.31	V	3	Apakah instansi/perusahaan anda secara periodik menguji dan mengevaluasi tingkat/status kepatuhan program keamanan informasi yang ada (mencakup pengecualian atau kondisi ketidakpatuhan lainnya) untuk memastikan bahwa keseluruhan inisiatif tersebut, termasuk langkah pembenahan yang diperlukan, telah diterapkan secara efektif?
4.32	V	3	Apakah instansi/perusahaan anda mempunyai rencana dan program peningkatan keamanan informasi untuk jangka menengah/panjang (1-3-5 tahun) yang direalisasikan secara konsisten?
			Total Nilai Evaluasi Kerangka Kerja
			75

Bagian V: Pengelolaan Aset Informasi			
Bagian ini mengevaluasi kelengkapan pengamanan aset informasi, termasuk keseluruhan siklus penggunaan aset tersebut.			
[Penilaian] Tidak Dilakukan; Dalam Perencanaan; Dalam Penerapan atau Diterapkan Sebagian; Diterapkan Secara Menyeluruh			Status
#	Pengelolaan Aset Informasi		
5.1	II	1	Apakah tersedia daftar inventaris aset informasi dan aset yang berhubungan dengan proses teknologi informasi secara lengkap, akurat dan terpelihara ? (termasuk kepemilikan aset)
			Diterapkan Secara Menyeluruh
5.2	II	1	Apakah tersedia definisi klasifikasi aset informasi yang sesuai dengan peraturan perundangan yang berlaku?
			Diterapkan Secara Menyeluruh
5.3	II	1	Apakah tersedia proses yang mengevaluasi dan mengklasifikasi aset informasi sesuai tingkat kepentingan aset bagi instansi/perusahaan dan keperluan pengamanannya?
			Dalam Perencanaan
5.4	II	1	Apakah tersedia definisi tingkatan akses yang berbeda dari setiap klasifikasi aset informasi dan matriks yang merekam alokasi akses tersebut
			Diterapkan Secara Menyeluruh
5.5	II	1	Apakah tersedia proses untuk mengidentifikasi dan menginventarisir syarat retensi aset informasi sesuai dengan peraturan perundangan yang ada dan menghapusnya jika sudah melewati batas retensi tersebut
			Diterapkan Secara Menyeluruh
5.6	II	1	Apakah tersedia proses untuk mengevaluasi kepatuhan terhadap syarat retensi dan menghapus aset informasi jika sudah melewati batas retensi tersebut
			Diterapkan Secara Menyeluruh
5.7	II	1	Apakah tersedia proses pengelolaan perubahan terhadap sistem, proses bisnis dan proses teknologi informasi (termasuk perubahan konfigurasi) yang diterapkan secara konsisten?
			Diterapkan Secara Menyeluruh
5.8	II	1	Apakah tersedia proses pengelolaan konfigurasi yang diterapkan secara konsisten?
			Diterapkan Secara Menyeluruh
5.9	II	1	Apakah tersedia proses untuk merilis suatu aset baru ke dalam lingkungan operasional dan memutakhirkan inventaris aset informasi?
			Diterapkan Secara Menyeluruh
			Apakah instansi/perusahaan anda memiliki dan menerapkan kontrol keamanan di bawah ini, sebagai kelanjutan dari proses penerapan mitigasi risiko?
5.10	II	1	Definis tanggungjawab pengamanan informasi secara individual untuk semua personel di instansi/perusahaan anda
			Diterapkan Secara Menyeluruh
5.11	II	1	Tata tertib penggunaan komputer, email, internet dan intranet
			Dalam Penerapan / Diterapkan Sebagian
5.12	II	1	Tata tertib pengamanan dan penggunaan aset instansi/perusahaan terkait HAKI
			Dalam Penerapan / Diterapkan Sebagian
5.13	II	1	Peraturan terkait instalasi piranti lunak di aset TI milik instansi/perusahaan
			Diterapkan Secara Menyeluruh
5.14	II	1	Peraturan penggunaan data pribadi yang mensyaratkan pemberian ijin tertulis oleh pemilik data pribadi
			Diterapkan Secara Menyeluruh
5.15	II	1	Pengelolaan identitas elektronik dan proses otentikasi (username & password) termasuk kebijakan terhadap pelanggaran
			Diterapkan Secara Menyeluruh
5.16	II	1	Persyaratan dan prosedur pengelolaan/pemberian akses, otentikasi dan otorisasi untuk menggunakan aset informasi
			Diterapkan Secara Menyeluruh
5.17	II	1	Ketetapan terkait waktu penyimpanan untuk klasifikasi data yang ada dan syarat penghancuran data
			Diterapkan Secara Menyeluruh
5.18	II	1	Ketetapan terkait pertukaran data dengan pihak eksternal dan pengamanannya
			Diterapkan Secara Menyeluruh
5.19	II	1	Proses penyidikan/investigasi untuk menyelesaikan insiden terkait kegagalan keamanan informasi
			Diterapkan Secara Menyeluruh
5.20	II	1	Prosedur back-up dan uji coba pengembalian data (restore) secara berkala
			Diterapkan Secara Menyeluruh
5.21	II	2	Ketentuan pengamanan fisik yang disesuaikan dengan definisi zona dan klasifikasi aset yang ada di dalamnya
			Diterapkan Secara Menyeluruh
5.22	III	2	Proses pengecekan latar belakang SDM
			Diterapkan Secara Menyeluruh
5.23	III	2	Proses pelaporan insiden keamanan informasi kepada pihak eksternal ataupun pihak yang berwajib.
			Diterapkan Secara Menyeluruh
5.24	III	2	Proses dan metoda untuk penghancuran informasi yang sudah tidak diperlukan dan sesuai dengan klasifikasi informasi (mis: secure delete, jenis/Kerapatan shredder dll). Termasuk didalamnya laporan bukti penghancuran informasi ?
			Diterapkan Secara Menyeluruh
5.25	III	2	Prosedur kajian penggunaan akses (user access review) dan hak aksesnya (user access rights) berikut langkah pembenahan apabila terjadi ketidaksesuaian (non-conformity) terhadap kebijakan yang berlaku
			Diterapkan Secara Menyeluruh
5.26	III	2	Prosedur untuk user yang mutasi/keluar atau tenaga kontrak/outsource yang habis masa kerjanya.
			Diterapkan Secara Menyeluruh
5.27	III	3	Apakah tersedia daftar data/informasi yang harus di-backup dan laporan analisa kepatuhan terhadap prosedur backup-nya?
			Diterapkan Secara Menyeluruh
5.28	III	3	Apakah tersedia daftar rekaman pelaksanaan keamanan informasi dan bentuk pengamanan yang sesuai dengan klasifikasinya?
			Diterapkan Secara Menyeluruh
5.29	III	3	Apakah telah diterapkan proses dan metoda untuk mengaburkan data (data masking) agar hanya dapat dilihat oleh pihak yang mempunyai otoritas sesuai regulasi atau kebijakan? Mis: pengamanan data pribadi, data sensitif
			Diterapkan Secara Menyeluruh
5.30	III	3	Apakah tersedia prosedur penggunaan perangkat pengolahan informasi milik pihak ketiga (termasuk perangkat milik pribadi dan mitra kerja/vendor) dengan memastikan aspek HAKI dan pengamanan akses yang digunakan?
			Diterapkan Secara Menyeluruh
#	Pengamanan Layanan Infrastruktur Awan (Cloud Service)		
5.31	III	2	Apakah instansi/perusahaan sudah melakukan kajian risiko terkait penggunaan layanan berbasis cloud dan menyesuaikan kebijakan keamanan informasi terkait layanan ini?
			Diterapkan Secara Menyeluruh
5.32	III	2	Apakah instansi/perusahaan sudah menetapkan data apa saja yang akan disimpan/diolah/dipertukarkan melalui layanan berbasis cloud?
			Diterapkan Secara Menyeluruh
5.33	III	2	Apakah instansi/perusahaan sudah menetapkan kebijakan dan menerapkan langkah pengamanan data pribadi yang disimpan/diolah/dipertukarkan melalui layanan cloud?
			Diterapkan Secara Menyeluruh
5.34	III	2	Apakah instansi/perusahaan sudah mengkaji, menetapkan pembagian tanggung jawab keamanan informasi antara perusahaan dan penyelenggara layanan cloud ?
			Diterapkan Secara Menyeluruh
5.35	III	2	Apakah instansi/perusahaan sudah mengkaji, menetapkan kriteria dan memastikan aspek hukum (yurisdiksi, hak dan kewenangan) terkait penggunaan layanan berbasis cloud?
			Diterapkan Secara Menyeluruh
5.36	III	2	Apakah instansi/perusahaan sudah mengevaluasi penyelenggara layanan cloud terkait reputasi penyelenggaranya?
			Diterapkan Secara Menyeluruh
5.37	III	2	Apakah instansi/perusahaan sudah menetapkan standar keamanan teknis penggunaan layanan cloud, termasuk aspek penggunaannya oleh pengguna di internal instansi/perusahaan?
			Diterapkan Secara Menyeluruh
5.38	III	2	Apakah instansi/perusahaan sudah mengevaluasi kelayakan keamanan layanan cloud termasuk aspek keterediannya dan pemenuhan sertifikasi layanan berbasis ISO 27001?
			Diterapkan Secara Menyeluruh
5.39	III	2	Apakah instansi/perusahaan sudah memiliki proses pelaporan insiden terkait layanan cloud?
			Diterapkan Secara Menyeluruh
5.40	III	3	Apakah instansi/perusahaan sudah memiliki kebijakan, strategi dan proses untuk mengganti layanan cloud atau menyediakan fasilitas pengganti apabila terjadi gangguan sementara pada layanan tersebut?
			Diterapkan Secara Menyeluruh
5.41	III	3	Apakah instansi/perusahaan sudah memiliki proses untuk menghentikan layanan cloud, termasuk proses pengamanan data yang ada (memindahkan dan menghapus data)?
			Diterapkan Secara Menyeluruh
#	Pengamanan Fisik		
5.42	II	1	Apakah sudah diterapkan pengamanan fasilitas fisik (lokasi kerja) yang sesuai dengan kepentingan/klasifikasi aset informasi, secara berapis dan dapat mencegah upaya akses oleh pihak yang tidak berwenang?
			Diterapkan Secara Menyeluruh
5.43	II	1	Apakah tersedia proses untuk mengelola alokasi kunci masuk (fisik dan elektronik) ke fasilitas fisik?
			Diterapkan Secara Menyeluruh
5.44	II	1	Apakah infrastruktur komputasi terlindungi dari dampak lingkungan atau api dan berada dalam kondisi dengan suhu dan kelembaban yang sesuai dengan prasyarat pabrikannya?
			Diterapkan Secara Menyeluruh
5.45	II	1	Apakah infrastruktur komputasi yang terpasang terlindungi dari gangguan pasokan listrik atau dampak dari petir?
			Diterapkan Secara Menyeluruh
5.46	II	1	Apakah infrastruktur komputasi yang terpasang dapat dipantau melalui CCTV ?
			Dalam Penerapan / Diterapkan Sebagian
5.47	II	1	Apakah tersedia peraturan pengamanan perangkat komputasi milik instansi/perusahaan anda apabila digunakan di luar lokasi kerja resmi (kantor)?
			Dalam Penerapan / Diterapkan Sebagian
5.48	II	1	Apakah tersedia proses untuk memindahkan aset TIK (piranti lunak, perangkat keras, data/informasi dll) dari lokasi yang sudah ditetapkan (termasuk pemutakhiran lokasinya dalam daftar inventaris)?
			Diterapkan Secara Menyeluruh
5.49	II	2	Apakah konstruksi ruang penyimpanan perangkat pengolahan informasi penting menggunakan rancangan dan material yang dapat menangulangi risiko kebakaran dan dilengkapi dengan fasilitas pendukung (deteksi kebakaran/asap, pemadam api, pengatur suhu dan kelembaban) yang sesuai?
			Dalam Penerapan / Diterapkan Sebagian
5.50	II	2	Apakah tersedia proses untuk memeriksa (inspeksi) dan merawat: perangkat komputer, fasilitas pendukungnya dan kelayakan keamanan lokasi kerja untuk menempatkan aset informasi penting?
			Diterapkan Secara Menyeluruh
5.51	II	2	Apakah tersedia mekanisme pengamanan dalam pengiriman aset informasi (perangkat dan dokumen) yang melibatkan pihak ketiga?
			Diterapkan Secara Menyeluruh
5.52	II	2	Apakah tersedia peraturan untuk mengamankan lokasi kerja penting (ruang server, ruang arsip) dari risiko perangkat atau bahan yang dapat membahayakan aset informasi (termasuk fasilitas pengolahan informasi) yang ada di dalamnya? (misal larangan penggunaan telpon genggam di dalam ruang server, menggunakan kamera dll)
			Dalam Penerapan / Diterapkan Sebagian
5.53	III	3	Apakah tersedia proses untuk mengamankan lokasi kerja dari keberadaan/kehadiran pihak ketiga yang bekerja untuk kepentingan instansi/perusahaan anda?
			Dalam Penerapan / Diterapkan Sebagian
			Total Nilai Evaluasi Pengelolaan Aset
			185

Bagian VI: Teknologi dan Keamanan Informasi				
Bagian ini mengevaluasi kelengkapan, konsistensi dan efektifitas penggunaan teknologi dalam pengamanan aset informasi.				
[Penilaian] Tidak Dilakukan; Dalam Perencanaan; Dalam Penerapan atau Diterapkan Sebagian; Diterapkan Secara Menyeluruh				Status
#	Pengamanan Teknologi			
6.1	II	1	Apakah layanan TIK (sistem komputer) yang menggunakan internet sudah dilindungi dengan lebih dari 1 lapis pengamanan?	Diterapkan Secara Menyeluruh
6.2	II	1	Apakah jaringan komunikasi disegmentasi sesuai dengan kepentingannya (pembagian instansi/perusahaan, kebutuhan aplikasi, jalur akses khusus, dll)?	Diterapkan Secara Menyeluruh
6.3	II	1	Apakah tersedia konfigurasi standar untuk keamanan sistem bagi keseluruhan aset jaringan, sistem dan aplikasi, yang dimutakhirkan sesuai perkembangan (standar industri yang berlaku) dan kebutuhan?	Diterapkan Secara Menyeluruh
6.4	III	2	Apakah tersedia proses pengelolaan konfigurasi perangkat komputasi (server, perangkat jaringan, sistem operasi dan aplikasi) yang diterapkan secara konsisten?	Diterapkan Secara Menyeluruh
6.5	IV	3	Apakah perangkat komputasi terpasang tersebut sudah dikaji ulang secara berkala sesuai dengan konfigurasi standar untuk keamanan sistem, dipantau efektivitasnya dan dimutakhirkan/disesuaikan konfigurasnyai melalui proses Manajemen Perubahan (<i>change management</i>)?	Diterapkan Secara Menyeluruh
6.6	II	1	Apakah jaringan, sistem dan aplikasi yang digunakan secara rutin dipindai untuk mengidentifikasi kemungkinan adanya celah kelemahan atau perubahan/keutuhan konfigurasi?	Diterapkan Secara Menyeluruh
6.7	II	1	Apakah keseluruhan infrastruktur jaringan, sistem dan aplikasi dirancang untuk memastikan ketersediaan (rancangan redundan) sesuai kebutuhan/persyaratan yang ada?	Diterapkan Secara Menyeluruh
6.8	II	1	Apakah keseluruhan infrastruktur jaringan, sistem dan aplikasi dimonitor untuk memastikan ketersediaan kapasitas yang cukup untuk kebutuhan yang ada dan efektivitas keamanannya?	Diterapkan Secara Menyeluruh
6.9	II	1	Apakah setiap perubahan dalam sistem informasi secara otomatis terekam di dalam log?	Diterapkan Secara Menyeluruh
6.10	II	1	Apakah upaya akses oleh yang tidak berhak secara otomatis terekam di dalam log?	Diterapkan Secara Menyeluruh
6.11	II	1	Apakah semua log dianalisa secara berkala untuk memastikan akurasi, validitas dan kelengkapan isinya (untuk kepentingan jejak audit dan forensik)?	Diterapkan Secara Menyeluruh
			"[Catatan Periksa] Minimal yang harus di log adalah sbb : 1. outbound and inbound trafik jaringan; 2. Akses terhadap sistem, server, perangkat jaringan, aplikasi kritis ; 3. penggunaan file sistem dan konfigurasi jaringan ; 4. dari perangkat keamanan [spt. antivirus, IDS, intrusion prevention system (IPS), web filters, firewalls, data leakage prevention]; 5. event log yang berhubungan dengan sistem dan aktifitas jaringan; "	
6.12	II	1	Apakah instansi/perusahaan anda menerapkan enkripsi untuk melindungi aset informasi penting sesuai kebijakan pengelolaan yang ada?	Diterapkan Secara Menyeluruh
6.13	III	2	Apakah instansi/perusahaan anda mempunyai standar dalam menggunakan enkripsi?	Diterapkan Secara Menyeluruh
6.14	III	2	Apakah instansi/perusahaan anda menerapkan pengamanan untuk mengelola kunci enkripsi (termasuk sertifikat elektronik) yang digunakan, termasuk siklus penggunaannya?	Dalam Penerapan / Diterapkan Sebagian
6.15	III	2	Apakah semua sistem dan aplikasi secara otomatis mendukung dan menerapkan penggantian <i>password</i> secara otomatis, termasuk menon-aktifkan <i>password</i> , mengatur kompleksitas/panjangnya dan penggunaan kembali <i>password</i> lama?	Dalam Penerapan / Diterapkan Sebagian
6.16	III	2	Apakah akses yang digunakan untuk mengelola sistem (administrasi sistem) menggunakan bentuk pengamanan khusus yang berlapis?	Diterapkan Secara Menyeluruh
6.17	III	2	Apakah sistem dan aplikasi yang digunakan sudah menerapkan pembatasan waktu akses termasuk otomatisasi proses <i>timeouts</i> , <i>lockout</i> setelah kegagalan <i>login</i> , dan penarikan akses?	Diterapkan Secara Menyeluruh
6.18	III	2	Apakah instansi/perusahaan anda menerapkan pengamanan untuk mendeteksi dan mencegah penggunaan akses jaringan (termasuk jaringan nirkabel) yang tidak resmi?	Diterapkan Secara Menyeluruh
6.19	II	1	Apakah instansi/perusahaan anda menerapkan bentuk pengamanan khusus untuk melindungi akses dari luar instansi/perusahaan?	Diterapkan Secara Menyeluruh
6.20	II	1	Apakah sistem operasi untuk setiap perangkat <i>desktop</i> dan <i>server</i> dimutakhirkan dengan versi terkini?	Dalam Penerapan / Diterapkan Sebagian
6.21	II	1	Apakah setiap <i>desktop</i> dan <i>server</i> dilindungi dari penyerangan virus (<i>malware</i>)?	Diterapkan Secara Menyeluruh
6.22	III	2	Apakah ada rekaman dan hasil analisa (jejak audit - <i>audit trail</i>) yang mengkonfirmasi bahwa antivirus/antimalware telah dimutakhirkan secara rutin dan sistematis?	Diterapkan Secara Menyeluruh
6.23	III	2	Apakah adanya laporan penyerangan virus/malware yang gagal/sukses ditindaklanjuti dan diselesaikan?	Diterapkan Secara Menyeluruh

6.24	III	2	Apakah instansi/perusahaan anda secara rutin menganalisa dan menetapkan website yang membahayakan perusahaan atau tidak seharusnya diakses karyawan? Untuk selanjutnya website tersebut diblok agar tidak dapat diakses.	Dalam Penerapan / Diterapkan Sebagian
6.25	III	2	Apakah keseluruhan jaringan, sistem dan aplikasi sudah menggunakan mekanisme sinkronisasi waktu yang akurat, sesuai dengan standar yang ada?	Diterapkan Secara Menyeluruh
6.26	III	2	Apakah instansi/perusahaan anda sudah menetapkan prinsip pengembangan aplikasi yang aman (<i>secure coding</i>) yang digunakan untuk pengembangan aplikasi secara internal (<i>in-house</i>) maupun yang melibatkan pihak eksternal? misal: menggunakan standard OWASP 10	Diterapkan Secara Menyeluruh
6.27	III	2	Apakah instansi/perusahaan anda sudah menerapkan proses perencanaan pengembangan sistem? (Dengan mempertimbangkan hasil pemrograman yang tidak baik/laik pada sistem sebelumnya, konfigurasi <i>software development tool</i> yang aman (<i>secure</i>), kontrol terhadap lingkungan pengembangan, desain arsitektur yang aman)	Diterapkan Secara Menyeluruh
6.28	III	2	Apakah instansi/perusahaan anda menerapkan proses <i>source code review</i> (baik secara manual atau menggunakan piranti lunak) sebelum dijalankan di lingkungan produksi?	Dalam Penerapan / Diterapkan Sebagian
6.29	II	1	Apakah instansi/perusahaan anda menerapkan kontrol akses untuk <i>source code</i> aplikasi ?	Diterapkan Secara Menyeluruh
6.30	III	2	Apakah setiap aplikasi yang ada memiliki spesifikasi dan fungsi keamanan yang diverifikasi/validasi pada saat proses pengembangan dan uji coba?	Diterapkan Secara Menyeluruh
6.31	III	3	Apakah instansi/perusahaan anda secara rutin menganalisa dan memperbaiki jika ditemukan ancaman baru (misal adanya laporan kelemahan dan/atau teknik exploit baru) yang berdampak pada keamanan sistem aplikasi?	Diterapkan Secara Menyeluruh
6.32	III	3	Apakah instansi/perusahaan anda menerapkan lingkungan pengembangan dan uji coba yang sudah diamankan sesuai dengan standar platform teknologi yang ada dan digunakan untuk seluruh siklus hidup sistem yang dibangun?	Dalam Penerapan / Diterapkan Sebagian
6.33	III	3	Apakah instansi/perusahaan sudah menerapkan proses atau mekanisme untuk mencegah terungkapnya informasi sensitif ke luar dari perusahaan (misal membatasi/mengkarantina lampiran email atau memblokir pengiriman dokumen/data ke luar) ?	Diterapkan Secara Menyeluruh
6.34	IV	3	Apakah instansi/perusahaan sudah menerapkan teknologi (DLP Data Leakage Prevention) untuk mencegah terungkapnya informasi sensitif ke luar dari perusahaan ?	Dalam Perencanaan
6.35	IV	3	Apakah instansi/perusahaan anda melibatkan pihak independen untuk mengkaji kehandalan keamanan informasi secara rutin?	Dalam Penerapan / Diterapkan Sebagian
Total Nilai Evaluasi Teknologi dan Keamanan Informasi				165

Bagian V

Bagian ini m

[Penilaian]
Secara Men

#		
7.1	II	1
7.2	II	1
7.3	II	1
7.4	II	1
7.5	II	2
7.6	II	2
7.7	III	2
7.8	III	2
7.9	III	2
7.10	III	2
7.11	III	2
7.12	III	2
7.13	III	2
7.14	III	2
7.15	III	2
7.16	III	2

II: Pelindungan Data Pribadi

mengevaluasi kelengkapan, konsistensi dan efektifitas penerapan kontrol keamanan terkait Pelindungan Data Pribadi

Tidak Dilakukan; Dalam Perencanaan; Dalam Penerapan atau Diterapkan Sebagian; Diterapkan sepenuhnya

Pelindungan Data Pribadi

Apakah instansi/perusahaan sudah mendokumentasikan jenis dan bentuk (dokumen kertas/elektronik) data pribadi yang disimpan, diolah dan dipertukarkan dengan pihak eksternal?

Apakah instansi/perusahaan sudah menetapkan alur pemrosesan data di internal dan pertukaran data dengan pihak eksternal, termasuk kapan dan dimana data pribadi tersebut diperoleh?

Apakah proses terkait penyimpanan, pengolahan dan pertukaran data pribadi di instansi/perusahaan sudah didokumentasikan?

Apakah instansi/perusahaan sudah memiliki kebijakan terkait Pelindungan Data Pribadi sesuai dengan Peraturan dan Perundangan yang berlaku?

Apakah instansi/perusahaan sudah menunjuk fungsi/unit Pejabat Pelindung Data Pribadi yang bertanggung-jawab dan berwenang dalam penerapan kebijakan dan proses Pelindungan Data Pribadi?

Apakah instansi/perusahaan sudah menganalisa dampak terkait terungkapnya data pribadi yang disimpan, diolah dan dipertukarkan secara ilegal atau karena insiden lain?

Apakah kajian risiko keamanan pada instansi/perusahaan sudah memasukkan aspek Pelindungan Data Pribadi?

Apakah mekanisme pelindungan data pribadi sudah diterapkan sesuai keperluan mitigasi risiko dan peraturan perundangan yang berlaku?

Apakah instansi/perusahaan sudah menjalankan program peningkatan pemahaman/kepedulian kepada seluruh pegawai terkait Pelindungan Data Pribadi, termasuk hal-hal terkait Peraturan

Apakah instansi/perusahaan sudah mendapatkan persetujuan dari pemilik data pribadi saat mengambil data tersebut, termasuk penjelasan hak pemilik data, apa saja yang akan diberlakukan pada data pribadi tersebut dan menyimpan catatan persetujuan tersebut ?

Apakah instansi/perusahaan sudah memiliki proses untuk melaporkan insiden terkait terungkapnya data pribadi?

Apakah instansi/perusahaan sudah menerapkan proses yang menjamin hak pemilik data pribadi untuk mengakses data tersebut?

Apakah instansi/perusahaan sudah menerapkan proses yang terkait dapat memastikan data pribadi tersebut akurat dan termutakhirkan?

Apakah instansi/perusahaan sudah menerapkan proses terkait periode penyimpanan data pribadi dan penghapusan/pemusnahannya sesuai dengan peraturan atau perjanjian dengan pemilik data?

Apakah instansi/perusahaan sudah menerapkan proses terkait penghapusan/pemusnahan data apabila sudah tidak ada keperluan yang sah untuk menyimpan/mengolahnya lebih lanjut atau atas permintaan pemilik data dan menyimpan catatan proses tersebut?

Apakah instansi/perusahaan sudah menerapkan proses terkait pengungkapan data pribadi atas permintaan resmi aparat penegak hukum?

Total Nilai Evaluasi Pelindungan Data Pribadi

Jumlah pertanyaan Tahap 1
Jumlah pertanyaan Tahap 2
Jumlah pertanyaan Tahap 3
Batas Skor Min untuk Skor Tahap Penerapan 3

Total Skor Tahap Penerapan 1

Jawaban Tahap 1: Tidak Diterapkan

Jawaban Tahap 1: Dalam Perencanaan

Jawaban Tahap 1: Diterapkan Sebagian

Jawaban Tahap 1: Diterapkan Secara Menyeluruh

Total Skor Tahap Penerapan 1 & 2

Status Penilaian Tahap Penerapan 3

Jumlah Pertanyaan TK II

Jumlah Pertanyaan TK III

Jumlah Pertanyaan TK IV

Jumlah Pertanyaan TK V

Skor Tingkat Kematangan II

Skor Minimum Tingkat Kematangan II

Skor Pencapaian Tingkat Kematangan II

Status

Skor Tingkat Kematangan III

Validitas Tingkat Kematangan III

Skor Minimum Tingkat Kematangan III

Skor Pencapaian Tingkat Kematangan III

Status

Data Pribadi (PDP).
Status
Diterapkan Secara Menyeluruh
Dalam Penerapan / Diterapkan Sebagian
Diterapkan Secara Menyeluruh
Dalam Penerapan / Diterapkan Sebagian
Diterapkan Secara Menyeluruh
Dalam Penerapan / Diterapkan Sebagian
Diterapkan Secara Menyeluruh
Dalam Penerapan / Diterapkan Sebagian
Diterapkan Secara Menyeluruh
Diterapkan Secara Menyeluruh
Diterapkan Secara Menyeluruh
Diterapkan Secara Menyeluruh
Dalam Penerapan / Diterapkan Sebagian
Dalam Penerapan / Diterapkan Sebagian
Dalam Perencanaan
Dalam Perencanaan
66

Skor

3

2

3

2

6

4

6

4

6

6

6

6

4

4

2

2

4 12 Total Skor Pertanyaan Tahap 1

12

0

56

10 NO Status pemenuhan Tahap 1

0

0

2

2

66

Tidak Valid

6

10

0

0

20 4(1),2(2)

24

8 2.K1.2+x.K1.1

16 4.K1.2+x.K2.4

II 19.2

46 10(3)

60

No

36 x.K1.3+2.K2.2+x.K2.4

48 x.K1.3+6.K2.4+x.K2.6

No

[illegible]

Bagian VII		
Bagian ini me operasional p		
[Penilaian] Ti Menyeluruh		
#		
8.1		
8.1.1		1
8.1.2		1
8.1.3		1
8.1.4		1
8.1.5		1
8.1.6		1
8.1.7		1
8.2		
8.2.1		1
8.2.2		1
8.2.3		1
8.3		
8.3.1		1
8.3.2		1
8.3.3		1
8.3.4		1
8.3.5		1

8.3.6		1
8.3.7		1
8.3.8		1
8.4		
8.4.1		1
8.4.2		1
8.5		
8.5.1		1
8.5.2		1
8.6		
8.6.1		1
8.6.2		1
8.7		
8.7.1		1
8.7.2		1
8.7.3		1

I: Suplemen

ngevaluasi kelengkapan, konsistensi dan efektivitas penerapan mekanisme keamanan terkait risiko keterli
nyelenggaraan layanan instansi/perusahaan

idak Dilakukan; Dalam Perencanaan; Dalam Penerapan atau Diterapkan Sebagian; Diterapkan Secara

Pengamanan Keterlibatan Pihak Ketiga Penyedia Layanan

Manajemen Risiko dan Pengelolaan Keamanan pihak ketiga

Apakah instansi/perusahaan mengidentifikasi risiko keamanan informasi yang ada terkait dengan
kerjasama dengan pihak ketiga atau karyawan kontrak?

Apakah instansi/perusahaan mengkomunikasikan dan mengklarifikasi risiko keamanan informasi yang
ada pada pihak ketiga kepada mereka?

Apakah instansi/perusahaan mengklarifikasi persyaratan mitigasi risiko instansi/perusahaan dan
ekspektasi mitigasi risiko yang harus dipatuhi oleh pihak ketiga?

Apakah rencana mitigasi terhadap risiko yang diidentifikasi tersebut disetujui oleh manajemen pihak
ketiga atau karyawan kontrak?

Apakah instansi/perusahaan telah menerapkan kebijakan keamanan informasi bagi pihak ketiga secara
memadai, mencakup persyaratan pengendalian akses, penghancuran informasi, manajemen risiko
penyediaan layanan pihak ketiga, dan NDA bagi karyawan pihak ketiga?

Apakah kebijakan tersebut (7.1.1.5) telah dikomunikasikan kepada pihak ketiga dan mereka menyatakan
persetujuannya dalam dokumen kontrak, SLA atau dokumen sejenis lainnya?

Apakah hak audit TI secara berkala ke pihak ketiga/pihak ketiga telah ditetapkan sebagai bagian dan
persyaratan kontrak, dikomunikasikan dan disetujui pihak ketiga?

Termasuk di dalamnya akses terhadap laporan audit internal / eksternal tentang kondisi kontrol
keamanan informasi pihak ketiga/pihak ketiga?

Pengelolaan Sub-Kontraktor/Alih Daya pada Pihak Ketiga

Apakah pihak ketiga sudah mengidentifikasi risiko terkait alih daya, subkontraktor atau penyedia
teknologi/infrastruktur yang digunakan dalam layanannya?

Apakah pihak ketiga sudah menerapkan pengendalian risikonya dalam perjanjian dengan mereka atau
dokumen sejenis?

Apakah pihak ketiga melakukan pemantauan dan evaluasi terhadap kepatuhan alih daya, subkontraktor
atau penyedia teknologi/infrastruktur terhadap persyaratan keamanan yang ditetapkan?

Pengelolaan Layanan dan Keamanan Pihak Ketiga

Apakah instansi/perusahaan telah menetapkan proses, prosedur atau rencana terdokumentasi untuk
mengelola dan memantau layanan dan aspek keamanan informasi (termasuk pengamanan aset
informasi dan infrastruktur milik instansi/perusahaan yang diakses) dalam hubungan kerjasama dengan
pihak ketiga?

Apakah peran dan tanggung jawab pemantauan, evaluasi dan/atau audit aspek keamanan informasi
pihak ketiga telah ditetapkan dan/atau ditugaskan dalam unit organisasi tertentu?

Apakah tersedia laporan berkala tentang pencapaian sasaran tingkat layanan (SLA) dan aspek
keamanan yang disyaratkan dalam perjanjian komersil (kontrak)?

Apakah ada rapat secara berkala untuk memantau dan mengevaluasi pencapaian sasaran tingkat
layanan (SLA) dan aspek keamanan?

Apakah hasil pemantauan dan evaluasi terhadap laporan atau pembahasan dalam rapat berkala
tersebut didokumentasikan, dikomunikasikan dan ditindaklanjuti oleh pihak ketiga serta dilaporkan
kemajuannya kepada instansi/perusahaan?

Apakah instansi/perusahaan telah menetapkan rencana dan melakukan audit terhadap pemenuhan persyaratan keamanan informasi oleh pihak ketiga?
Apakah hasil audit tersebut ditindaklanjuti oleh pihak ketiga dengan melaporkan rencana perbaikan yang terukur dan bukti-bukti penerapan rencana tersebut?
Apakah kondisi terkait denda / penalti karena ketidakpatuhan pihak ketiga terhadap persyaratan dan / atau tingkat layanan telah didokumentasikan, dikomunikasikan, dipahami dan diterapkan?
Pengelolaan Perubahan Layanan dan Kebijakan Pihak Ketiga
Apakah instansi/perusahaan mengelola perubahan yang terjadi dalam hubungan dengan pihak ketiga yang menyangkut antara lain? - Perubahan layanan pihak ketiga; - Perubahan kebijakan, prosedur, dan/atau - Kontrol risiko pihak ketiga?
Apakah risiko yang menyertai perubahan tersebut dikaji, didokumentasikan dan ditetapkan rencana mitigasi barunya?
Penanganan Aset
Apakah pihak ketiga memiliki prosedur formal untuk menangani data selama dalam siklus hidupnya mulai dari pembuatan, pendaftaran, perubahan, dan penghapusan / penghancuran aset?
Apakah per untuk penghancuran (disposal) data secara aman telah disepakati bersama pihak ketiga (pihak ketiga)?
Pengelolaan Insiden oleh Pihak Ketiga
Apakah pihak ketiga memiliki prosedur untuk pelaporan, pemantauan, penanganan, dan analisis insiden keamanan informasi?
Apakah pihak ketiga memiliki bukti-bukti penerapan yang memadai dalam menangani insiden keamanan informasi?
Rencana Kelangsungan Layanan Pihak Ketiga
Apakah pihak ketiga memiliki kebijakan, prosedur atau rencana terdokumentasi untuk mengatasi kelangsungan layanan pihak ketiga dalam keadaan darurat/bencana?
Apakah kebijakan, prosedur atau rencana kelangsungan layanan tersebut telah diujicoba, didokumentasikan hasilnya dan dievaluasi efektivitasnya?
Apakah pihak ketiga memiliki organisasi atau tim khusus yang ditugaskan untuk mengelola proses kelangsungan layanannya?
Total Nilai Evaluasi Pengamanan Keterlibatan Pihak Ketiga Penyedia Layanan

batan pihak ketiga eksternal dalam		
Status	Skor	NOMOR DOKUMEN
	1.67	
Diterapkan Secara Menyeluruh	3	
Diterapkan Secara Menyeluruh	3	
Dalam Penerapan / Diterapkan Sebagian	2	
Dalam Penerapan / Diterapkan Sebagian	2	
Diterapkan Secara Menyeluruh	3	
Dalam Penerapan / Diterapkan Sebagian	2	
Dalam Penerapan / Diterapkan Sebagian	2	
Dalam Perencanaan	1	
Dalam Perencanaan	1	
Dalam Perencanaan	1	
Diterapkan Secara Menyeluruh	3	
Diterapkan Secara Menyeluruh	3	
Diterapkan Secara Menyeluruh	3	
Diterapkan Secara Menyeluruh	3	
Diterapkan Secara Menyeluruh	3	

Dalam Perencanaan	1	
Dalam Perencanaan	1	
Dalam Perencanaan	1	
Dalam Perencanaan	1	
Dalam Perencanaan	1	
Dalam Perencanaan	1	
Dalam Perencanaan	1	
Dalam Perencanaan	1	
Dalam Perencanaan	1	
Dalam Perencanaan	1	
Tidak Dilakukan	0	
Tidak Dilakukan	0	
56 %		

NAMA DOKUMEN	Catatan Revisi [ISO] [UUx] [PERx]

Indeks KAMI (Keamanan Informasi) Versi 5.0

Responden:

Pemerintah Aceh
Pemerintah Kabupaten Aceh Tengah
Dinas Komunikasi dan Informatika Kabupaten
Aceh Tengah

Komplek Setdakab Aceh Tengah
Alamat 2
Kota Kode Pos

(Kode Area) Nomor Telpn
diskominfo@acehtengahkab.go.id
13 April 2026

Skor Kategori SE

: 12

Kategori SE

Rendah

Hasil Evaluasi Akhir:

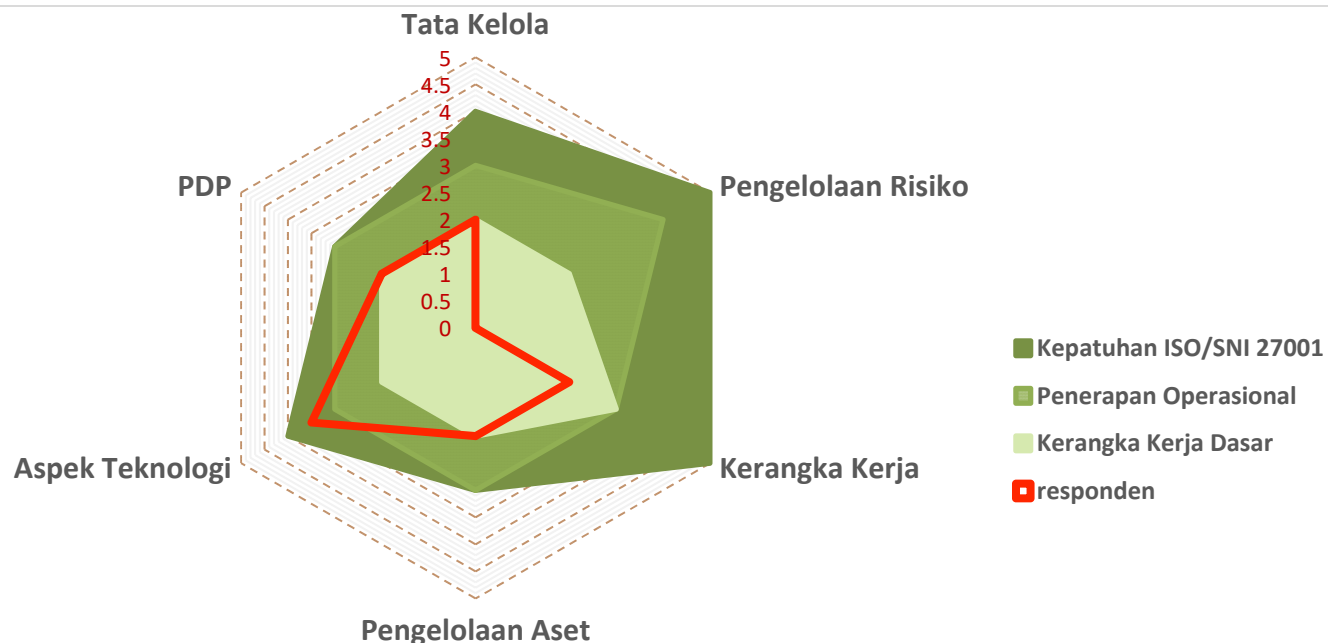
Cukup Baik

Tingkat Kelengkapan Penerapan
Standar ISO27001 sesuai Kategori



Tata Kelola	: 49	T. Kematangan:	II
Pengelolaan Risiko	: 23	T. Kematangan:	I
Kerangka Kerja Keamanan Informasi	: 75	T. Kematangan:	II
Pengelolaan Aset	: 185	T. Kematangan:	II
Teknologi dan Keamanan Informasi	: 165	T. Kematangan:	III+
Pelindungan Data Pribadi	: 66	T. Kematangan:	II
Pengamanan Keterlibatan P.Ketiga	: 56 %		

I
s/d
III+

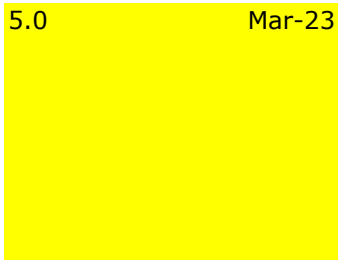


Versi	Tanggal
1.0	2009
2.0	2-Jun-11
2.1	30-Jun-11
2.2	10-Aug-11
2.3	19-Apr-12

3.0	15-Mar-15
3.1	15-Apr-15
4.0 Draft	5-Feb-19

11-Mar-19

4.1	5-Nov-19
4.2	25-Mei-2021
5.0	Mar-23



Keterangan perubahan

Rilis pertama

Penggunaan analisa Tingkat Kematangan

Kesalahan definisi rumus penentuan Tingkat Kematangan

Kesalahan definisi rumus penentuan Tingkat Kematangan

Kesalahan definisi rumus (penggunaan acuan sel) pada Tab "VI Teknologi" sel E48 untuk menentukan pencapaian TK IV. Rumus asalnya: $\text{IF}(\text{AND}(\text{E44}=\text{"Yes"}, \text{E43} \geq \text{F46}), \text{"Yes"}, \text{"No"})$ rumus yang benar $=\text{IF}(\text{AND}(\text{E43}=\text{"Yes"}, \text{E42} \geq \text{F46}), \text{"Yes"}, \text{"No"})$

Penyesuaian dengan perubahan kontrol di ISO/IEC 27001:2013 dan penggunaan Kategori Sistem Elek

Pemisahan kategori Cukup/Baik - menjadi 2 kategori terpisah

Revisi istilah/kata pada Kategori SE - "Teknik kriptografi khusus yang disertifikasi oleh Negara"

Revisi istilah "Instansi" menjadi "Perusahaan/Instansi"

Revisi Status "Perlu Perbaikan" --> "Pemenuhan Kerangka Kerja Dasar"

Revisi Kondisi "Proses Penerapan" --> "Penerapan Operasional"

Penambahan Area Evaluasi - Pihak Ketiga, Layanan Cloud dan Perlindungan Data Pribadi

Perubahan tata letak (layout) Dashboard

Revisi: Fetri Miftach, Haryatno Sabarman

Hasil QA oleh tim Asesor: M Heri Herman Aji, Pratiwi Widjiastuti, Denny Sadikin, Rakean Raksadipa, K
Sirkulasi Internal BSSN

Revisi dan Penambahan Redaksional oleh tim BSSN: Intan Rahayu

Revisi Redaksional Pada Chart Dashboard oleh tim BSSN: Gigih Supriyatno

Penambahan area evaluasi sesuai ISO 27001:2022, pada Kerangka Kerja, Pengelolaan Aset dan Teknologi

Pemindahan area evaluasi Suplemen - Penggunaan Infra Layanan Awan ke area evaluasi utama (Pengelolaan Aset)

Memisahkan area evaluasi Suplemen - Pelindungan Data Pribadi menjadi area sendiri/terpisah

Penyesuaian rumus perhitungan skor dan dashboard

Penambahan opsi kondisi "Tidak Berlaku/Relevan" pada sejumlah pertanyaan apabila area evaluasi memang tidak relevan dengan ruang lingkup

tronikyang didefinisikan oleh RPM SMPI

utsarina Adam